

STHX Technologies Gym Management Portal — Overall System Documentation

Version: 2.0 (Production Ready)

Provider: STHX Technologies

Tech Stack: FastAPI | SQLAlchemy | Python 3.13 | Brevo Email API | React | Vanilla CSS
Glassmorphism

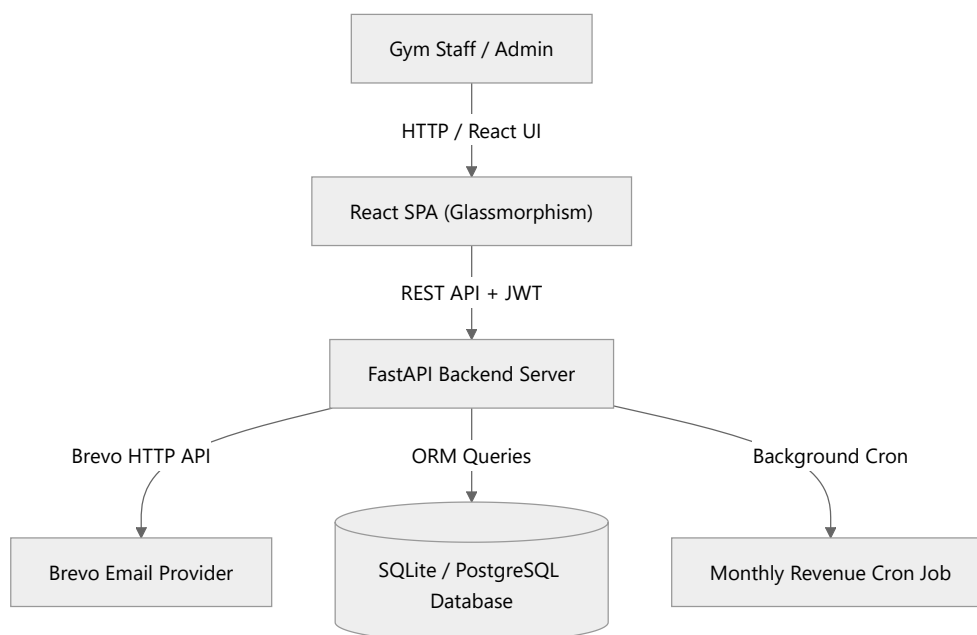
System Architecture: Multi-Tenant Repository-Service Architecture

Table of Contents

1. [System Overview](#) (#1-system-overview)
2. [Technology Stack & Architecture](#) (#2-technology-stack--architecture)
3. [Key Modules & Functionality](#) (#3-key-modules--functionality)
 - o [3.1 Authentication & Email Verification \(Brevo API\)](#) (#31-authentication--email-verification-brevo-api).
 - o [3.2 Role-Based Access & Distinct UI Avatars](#) (#32-role-based-access--distinct-ui-avatars).
 - o [3.3 Member Management & Registration Wizard](#) (#33-member-management--registration-wizard)
 - o [3.4 Payment Locking & Revenue Protection](#) (#34-payment-locking--revenue-protection).
 - o [3.5 Monthly Revenue Tracking & History Cron Job](#) (#35-monthly-revenue-tracking--history-cron-job).
 - o [3.6 Account-Isolated Activity Audit Logging](#) (#36-account-isolated-activity-audit-logging).
 - o [3.7 Settings & Dynamic Gym Branding](#) (#37-settings--dynamic-gym-branding)
 - o [3.8 Attendance Kiosk](#) (#38-attendance-kiosk).
 - o [3.9 Archive System & 60-Day Safeguard](#) (#39-archive-system--60-day-safeguard).
4. [Database Schema & Data Models](#) (#4-database-schema--data-models)
5. [API Sitemap & Endpoint Reference](#) (#5-api-sitemap--endpoint-reference)
6. [Design System & UI Guidelines](#) (#6-design-system--ui-guidelines).
7. [Environment Configuration & Security](#) (#7-environment-configuration--security).
8. [Deployment & Verification Guide](#) (#8-deployment--verification-guide)

1. System Overview

The **STHX Technologies Gym Management Portal** is a production-ready, multi-tenant SaaS application designed for gym owners, administrators, and receptionists. The portal streamlines end-to-end gym operations—from email-verified user onboarding and member registration to Automated Attendance, Payment Locking, 12-Month Rolling Revenue Tracking, and Dynamic White-Label Gym Branding.



2. Technology Stack & Architecture

Backend Architecture

- **Framework:** FastAPI (Asynchronous Python Web Framework)
- **Database ORM:** SQLAlchemy with Session-per-request pattern
- **Authentication:** JWT Bearer Tokens (`HS256` algorithm, 24-hour expiration)
- **Security & Hashing:** Python `secrets` module (cryptographically secure OTPs), PBKDF2-HMAC password hashing with salt
- **Rate Limiting:** Custom IP & Endpoint Rate Limiter (60 requests/minute per client)
- **Email Service:** Brevo (formerly Sendinblue) v3 HTTP SMTP API
(`https://api.brevo.com/v3/smtp/email`)

- **Background Tasks:** Python `apscheduler` / Async background cron runners for automated 1st-of-month revenue archiving

Frontend Architecture

- **Framework:** React Single Page Application (SPA)
- **Styling System:** Custom Vanilla CSS with Dark Blue Glassmorphism design tokens (`#060913` atmospheric backdrop, `#090D1B` glass panels)
- **Icons & Visuals:** FontAwesome & Inline SVG Icon library
- **Data Visualization:** Chart.js for revenue trend lines and membership plan distribution pie charts

3. Key Modules & Functionality

3.1 Authentication & Email Verification (Brevo API)

1. Registration Flow:

- User inputs **Full Name, Gym Name, Email, Password, Confirm Password**, and **System Role**.
- Password Policy: Minimum 8 characters, at least 1 uppercase letter, 1 lowercase letter, 1 number, and 1 special character (`@$!%*?&`).
- Duplicate email prevention checks unverified vs verified accounts.

2. OTP Email Delivery:

- Generates a 6-digit numeric code using Python `secrets.randbelow()`.
- Sends dark-blue glassmorphic HTML email template via Brevo HTTP API using `BREVO_API_KEY`, `EMAIL_FROM`, and `EMAIL_FROM_NAME`.
- OTP Expiry: **10 minutes**. Rate Limit: Max 5 resend requests per hour.

3. Forgot & Reset Password:

- Anti-enumeration design: Returns identical generic message regardless of email existence.
- Requires 6-digit OTP verification before allowing password reset.

3.2 Role-Based Access & Distinct UI Avatars

The system distinguishes between **Administrators** (`admin`) and **Gym Staff** (`receptionist`).

-  **Admin Account:**
 - Full system access (System Settings, Gym Branding, All Account Activity Logs, Plan management).
 - **PFP Avatar:** Gold & Purple gradient (`from-amber-500 via-purple-600 to-indigo-950`), glowing gold border ring,  crown role badge.
-  **Gym Staff / Receptionist Account:**
 - Operational access (Member Registration, Attendance Kiosk, Payments).
 - **PFP Avatar:** Cyan & Deep Blue gradient (`from-cyan-500 via-blue-600 to-slate-950`), glowing cyan border ring,  dumbbell role badge.

3.3 Member Management & Registration Wizard

- **Multi-Step Registration Wizard:**
 - Step 1: Member Personal Details (Name, Phone, Email, Gender, DOB, Emergency Contact).
 - Step 2: Plan Selection & Duration.
 - Step 3: **Registration Fee Toggle (ON/OFF)** — allows waiving or including the initial registration fee.
 - Step 4: Payment Method (Cash, Card, Online, Bank Transfer) & Automatic Payment Recording.
- **Member Code Generation:** Automatically assigns unique identifier formatted as `FM-YYYY-XXXX`.

3.4 Payment Locking & Revenue Protection

*[!IMPORTANT] **Revenue Protection Rule:** To prevent duplicate fee payments and revenue distortion, fee payment controls (`Pay` buttons across Members List, Payments Tab, and Profile Drawer) are **locked for the duration of an active membership** (e.g. 30 days).*

- Backend guard prevents processing payment requests if `expiry_date` is in the future.
- Visual state displays a locked badge:  Active (Expires DD/MM/YYYY).

3.5 Monthly Revenue Tracking & History Cron Job

- **Automated Cron Execution:** At 12:00 AM on the 1st of every month, a scheduled background job calculates the total completed revenue for the prior month per user account.
- **Archiving:** Stores the monthly revenue total into `monthly_revenue_history`.
- **12-Month Rolling Window:** Displays historical monthly revenue trend lines and comparisons on the Dashboard.

3.6 Account-Isolated Activity Audit Logging

- **Account Isolation:** Standard users view ONLY activity logs generated by their own account (`user_id == current_user.id`).
- **Admin Account Switcher:** Administrators can toggle between:
 -  `My Logs` (Current account activity)
 -  `All Accounts` (Global system activity)
 -  `Filter by Account` (Dropdown selector to inspect specific user account logs).

3.7 Settings & Dynamic Gym Branding

- **My Profile:**
 - User Full Name editable.
 - **Email Address Locked:** Rendered as a read-only field with  `Verified & Fixed` badge for identity security.
- **Security:** Change Password with current password verification & active session monitoring ("Logout from all devices").
- **Gym Branding & Media Assets** (Admin configurable):
 - **Gym Name:** Dynamically updates Top Header, Sidebar, and Printable Receipts.
 - **Official Gym Logo:** Upload PNG/WEBP/SVG logo to update internal workspace branding. (Note: Login screen uses fixed permanent STHX Technologies logo).
 - **Contact Details:** Phone, Email, Website, Physical Gym Address.
 - **Receipt Footer Message:** Custom message printed at the bottom of member receipts.

3.8 Attendance Kiosk

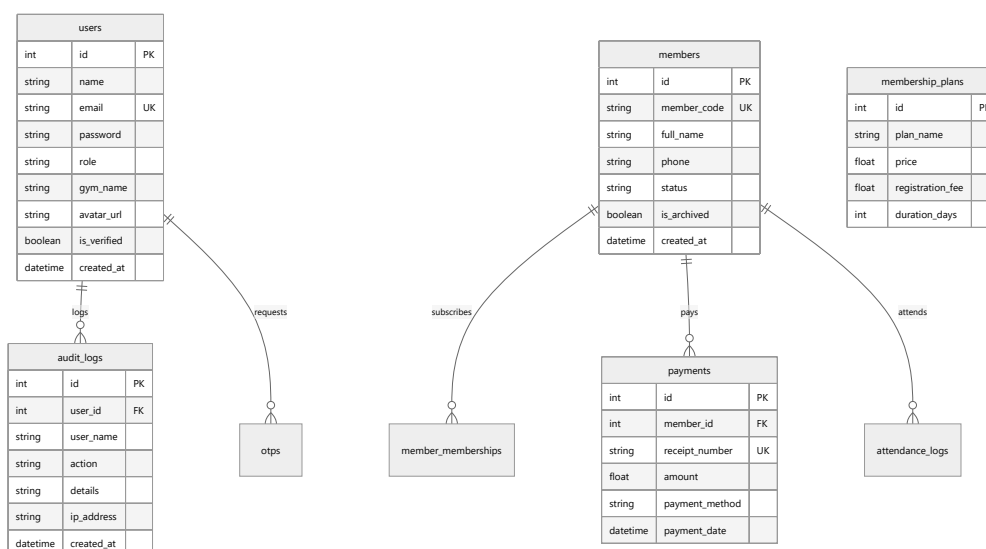
- Search members by name or member code.

- One-click **Check-In** and **Check-Out**.
- Auto-calculates session duration in minutes upon checkout.
- Real-time today's check-in counter and active session monitoring.

3.9 Archive System & 60-Day Safeguard

- Soft delete moves members to the **Archive** tab.
- Soft-deleted members are excluded from active counts and attendance kiosk.
- Can be restored to active status at any time or permanently deleted.

4. Database Schema & Data Models



5. API Sitemap & Endpoint Reference

Authentication Endpoints (`/api/auth/*`)

Method	Endpoint	Description	Auth Required
POST	<code>/api/auth/register</code>	Register new user & dispatch Brevo OTP	✗
POST	<code>/api/auth/verify-email</code>	Verify 6-digit OTP & activate account	✗
POST	<code>/api/auth/resend-verification</code>	Resend verification OTP (max 5/hr)	✗
POST	<code>/api/auth/login</code>	Authenticate user & return JWT tokens	✗
POST	<code>/api/auth/forgot-password</code>	Request password reset OTP	✗
POST	<code>/api/auth/verify-reset-otp</code>	Verify password reset OTP code	✗
POST	<code>/api/auth/reset-password</code>	Reset account password with OTP	✗

Member & Payment Endpoints (`/api/members/*` , `/api/payments/*`)

Method	Endpoint	Description	Auth Required
GET	<code>/api/members</code>	List members (filters: search, status, archived)	✓
POST	<code>/api/members</code>	Create new member & assign plan	✓
PUT	<code>/api/members/{id}</code>	Edit member details	✓
DELETE	<code>/api/members/{id}</code>	Soft delete member to Archive	✓
POST	<code>/api/members/{id}/restore</code>	Restore soft-deleted member	✓
DELETE	<code>/api/members/{id}/permanent</code>	Permanently remove member	✓ Admin
POST	<code>/api/payments</code>	Record fee payment & generate receipt	✓
GET	<code>/api/payments</code>	List payment transaction history	✓

Settings & Audit Endpoints (`/api/settings/*` , `/api/audit-logs`)

Method	Endpoint	Description	Auth Required
GET	<code>/api/settings/profile</code>	Get current user profile	✓
PUT	<code>/api/settings/profile</code>	Update profile (Name editable, Email locked)	✓
POST	<code>/api/settings/profile/avatar</code>	Upload user profile avatar image	✓
PUT	<code>/api/settings/password</code>	Change account security password	✓
GET	<code>/api/settings/branding</code>	Fetch Gym Branding configuration	✗
PUT	<code>/api/settings/branding</code>	Update Gym Branding details	✓ Admin
POST	<code>/api/settings/branding/logo</code>	Upload official Gym logo asset	✓ Admin
GET	<code>/api/audit-logs</code>	Fetch account-isolated activity logs	✓

6. Design System & UI Guidelines

Color Palette & Aesthetic Tokens

- **Background Portal:** `#060913` (Deep space dark background with subtle radial glow overlay)
- **Glassmorphism Panels:** `bg-[#090D1B]/90 backdrop-blur-md border border-white/10`
- **Accent Primary:** `#0066FF` (Neon blue glow button styling)
- **Cyan Accent:** `#06B6D4` (High-contrast data highlight text)
- **Admin Theme:** Gold/Purple accent (`#F59E0B` gold border ring & `#8B5CF6` gradient)
- **Typography:** Google Fonts — Montserrat (Headings) & Inter (Body text)

7. Environment Configuration & Security

Environment Variables (`.env`)

```
# Application Configuration
JWT_SECRET=sthxtechnologies_super_secret_jwt_key_2026
ALLOWED_ORIGINS=http://localhost:8000,http://127.0.0.1:8000
DATABASE_URL=sqlite:///./gym.db

# Brevo Email API Integration
BREVO_API_KEY=your_brevo_api_key_here
EMAIL_FROM=support@sthxtechnologies.com
EMAIL_FROM_NAME=STHX Technologies Gym Portal
```

8. Deployment & Verification Guide

Local Development Execution

1. Install Python 3.13 dependencies:

```
pip install fastapi uvicorn sqlalchemy pydantic requests passlib python-jose apscheduler
```

2. Start backend server:

```
python main.py
```

3. Access Portal in Browser:

- URL: `http://127.0.0.1:8000`
- Default Seed Admin: `admin@sthxtechnologies.com` / `admin123`

Documentation compiled and maintained by STHX Technologies.